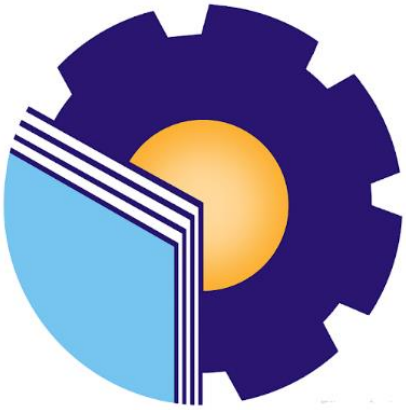
LAPORAN PRAKTIKUM

KEAMANAN PERANGKAT LUNAK

"EKSPLORASI KATEGORI PADA OWASP JUICE SHOP SECARA PASIF DAN PEMETAAN KE CWE"



DISUSUN OLEH:

SULESTARI (6304240033)

DOSEN PENGAMPU:

MUHAMMAD ASEP SUBANDRI, M.Kom

PROGRAM STUDI REKAYASA PERANGKAT LUNAK

JURUSAN TEKNIK INFORMATIKA

POLITEKNIK NEGERI BENGKALIS

TA 2025/2026

OUTPUT EKSPLORASI KATEGORI PADA OWASP JUICE SHOP SECARA PASIF DAN PEMETAAN KE CWE

CATATAN LINGKUNGAN

Pengujian keamanan perangkat lunak dilakukan menggunakan aplikasi OWASP Juice Shop yang dijalankan melalui Docker Desktop pada sistem operasi Windows. Pengujian dilakukan dengan bantuan OWASP ZAP untuk mengamati lalu lintas HTTP antara browser dan aplikasi target.

No.	Komponen	Keterangan
1.	Aplikasi target	OWASP Juice Shop
2.	Versi Juice Shop	20.2.0
3.	Alamat target	http://localhost:3000
4.	Port binding Docker	127.0.0.1:3000
5.	Tools pengujian	OWASP ZAP
6.	Versi OWASP ZAP	2.17.0
7.	Lingkungan pengujian	Docker Desktop pada Windows
8.	Metode pengujian	Manual Explore melalui browser yang diluncurkan oleh OWASP ZAP
9.	Tanggal praktikum	24 Oktober 2026
10.	Ketersediaan Score Board	Tersedia; Score Board dapat diakses dan menampilkan progres penyelesaian challenge.

VULNERABILITY CHECKLIST

Target: OWASP Juice Shop lokal (127.0.0.1:3000)

Metode: Pengamatan pasif melalui browser DevTools dan OWASP ZAP History.

ID	Asset	Kategori	Label Juice Shop	CWE	Status	Bukti

R-09	A-04	A01 — Broken Access Control	API keranjang (/rest/basket/6)	CWE-639 sebagai kandidat, belum terkonfirmasi.	Hipotesis	Endpoint /rest/basket/6 mengembalikan respons HTTP 200 OK yang memuat data keranjang dengan ID 6 dan UserId 25. Pengamatan ini belum membuktikan bahwa pengguna dapat mengakses keranjang di luar kewenangannya.
R-10	A-05	A02 — Security Misconfiguration	HTTP Security Headers	CWE-693 (usulan; tidak tercantum pada daftar CWE A02 OWASP)	Hipotesis	Respons halaman utama http://127.0.0.1:3000/ menghasilkan 200 OK. Header X-Content-Type-Options: nosniff dan X-Frame-Options: SAMEORIGIN ditemukan, sedangkan Content-Security-Policy tidak terlihat pada respons yang diperiksa. Pengamatan ini menjadi indikasi konfigurasi header yang perlu ditinjau, tetapi tidak

						membuktikan kerentanan secara keseluruhan.
R-11	A-08	A03 — Software Supply Chain Failures	Informasi versi aplikasi	CWE-1104 (kandidat; belum terkonfirmasi)	Teramati	Endpoint /rest/admin/application-version mengembalikan informasi versi aplikasi Juice Shop, yaitu 20.2.0, dengan respons HTTP 200 OK. Pengamatan ini membuktikan bahwa informasi versi aplikasi terlihat, tetapi tidak mengidentifikasi versi komponen pihak ketiga atau membuktikan adanya komponen yang tidak terpelihara. CWE-1104 hanya kandidat.
R-12	A-01	A04 — Cryptographic Failures	Informasi sensitif pada JWT	— (belum ada CWE yang terbukti sesuai)	Tidak Ditemukan	Pemeriksaan JWT pada Local Storage menunjukkan bahwa token menggunakan algoritma RS256 dengan klaim data bertipe object, serta bid dan iat bertipe number. Aplikasi lab diakses melalui HTTP.

						Berdasarkan pengamatan ini, belum ditemukan bukti langsung kelemahan algoritma kriptografi. Penggunaan HTTP dicatat sebagai keterbatasan keamanan lingkungan lab, bukan sebagai bukti kerentanan kriptografi pada aplikasi.
R-13	A-05	A05 — Injection	Pencarian produk	— (belum ada CWE yang dapat ditentukan)	Teramati	Permintaan pencarian dengan q=apple menghasilkan respons JSON berisi produk. Ini merupakan pengamatan terhadap titik input pencarian dan respons normal aplikasi. Tidak ditemukan bukti langsung bahwa input diproses sebagai perintah atau kueri; SQL injection tidak terbukti.
R-14	A-04	A06 — Insecure Design	Alur keranjang dan konfirmasi pesanan	— (belum ada kelemahan yang teridentifikasi)	Tidak ditemukan	Alur normal menampilkan produk dan harga hingga konfirmasi pesanan. Dalam pengamatan terbatas ini tidak ditemukan pelanggaran alur bisnis atau kontrol keamanan yang

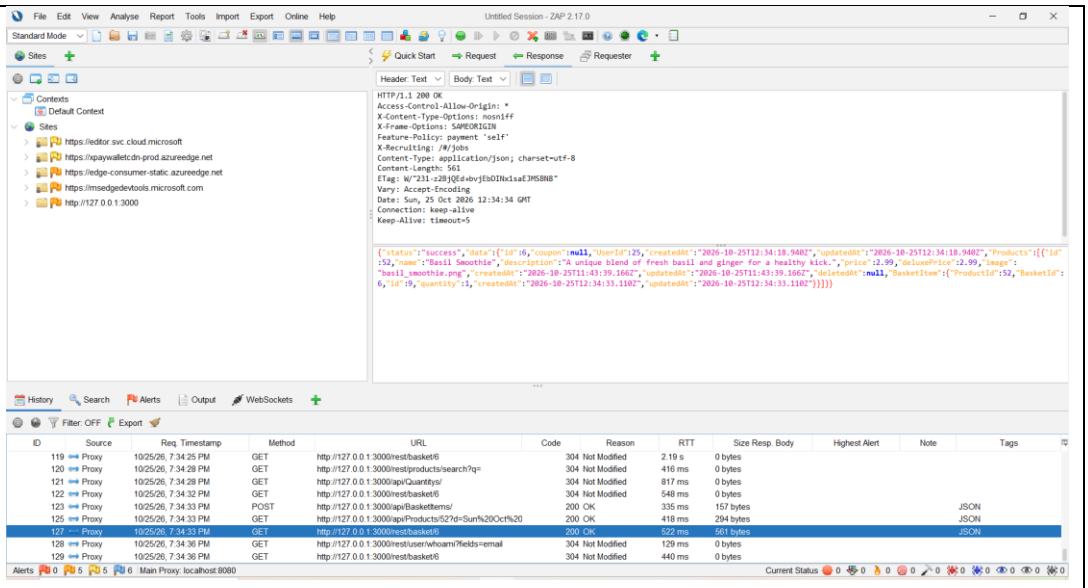
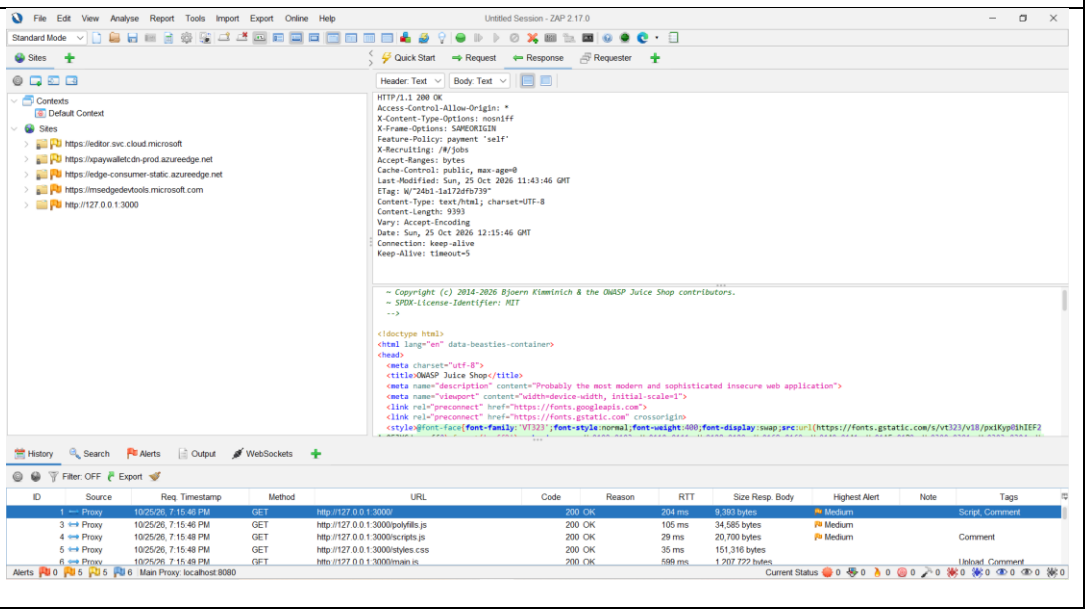
						gagal. Karena akar penyebab kelemahan desain belum teridentifikasi, CWE-841 tidak digunakan sebagai temuan.
R-15	A-01	A07 — Authentication Failures	Login dan autentikasi pengguna	CWE-307 (kandidat; pembatasan percobaan belum diverifikasi)	Teramati	Login biasa menghasilkan respons HTTP 200 OK dan token autentikasi. Ini membuktikan bahwa alur login normal diamati, tetapi tidak membuktikan ada atau tidaknya pembatasan percobaan login. CWE-307 hanya kandidat dan kelemahan autentikasi belum terkonfirmasi.
R-16	A-07	A08 — Software or Data Integrity Failures	JavaScript dan Local Storage	— (belum dapat ditentukan)	Tidak Ditemukan	Pengamatan kode sumber menunjukkan bahwa halaman memuat file JavaScript lokal, yaitu polyfills.js, scripts.js, dan main.js, serta menggunakan resource eksternal untuk font. Pencarian

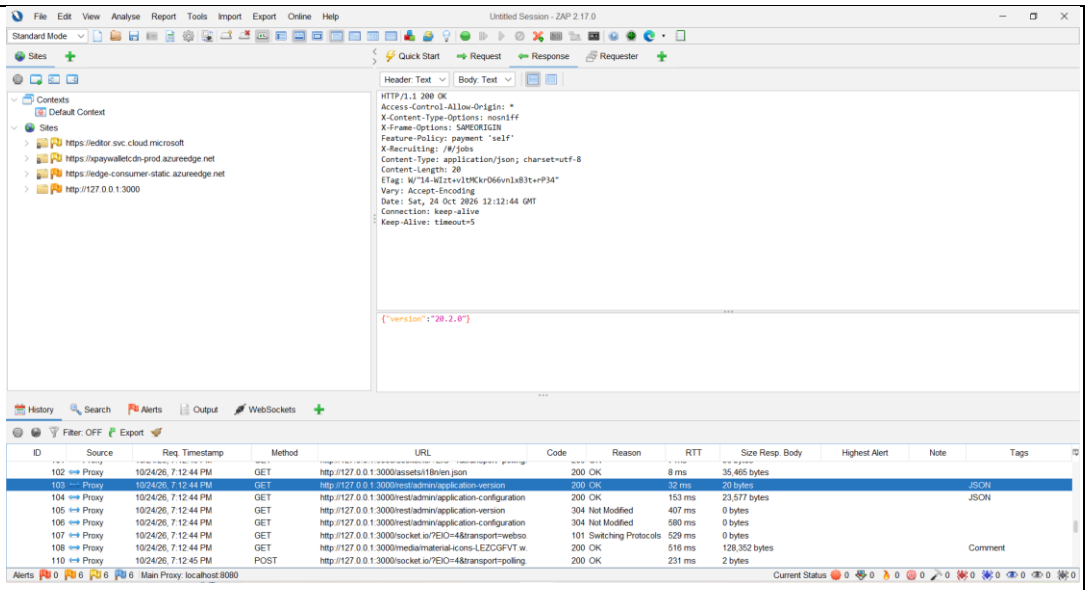
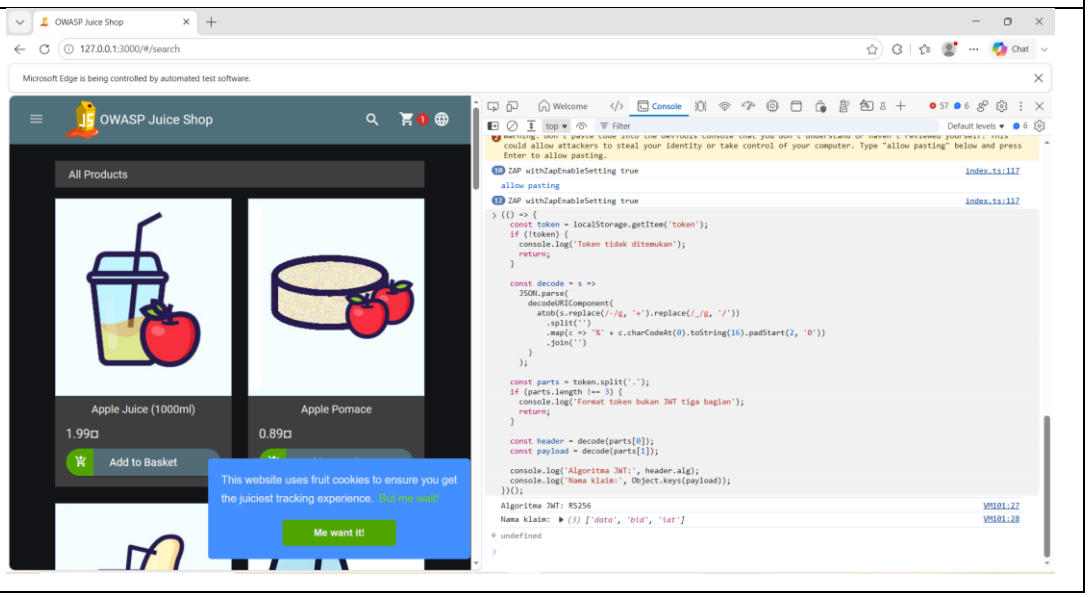
						atribut integrity tidak menemukan hasil pada kode sumber yang diperiksa. Pemeriksaan Local Storage juga hanya menemukan key token beserta value-nya. Berdasarkan pengamatan tersebut, belum ditemukan bukti langsung adanya kelemahan integritas pada sumber daya atau data sisi klien.
R-17	A-08	A09 — Security Logging and Alerting Failures	Browser Console	CWE-778 (kategori yang diperiksa; belum terkonfirmasi)	Tidak ditemukan	Console menampilkan AbortError dan kegagalan WebSocket. Gejala sisi klien ini tidak membuktikan kegagalan pencatatan atau alert pada server. Logging server tidak dapat dipastikan hanya dari pengamatan browser, sehingga tidak ditemukan

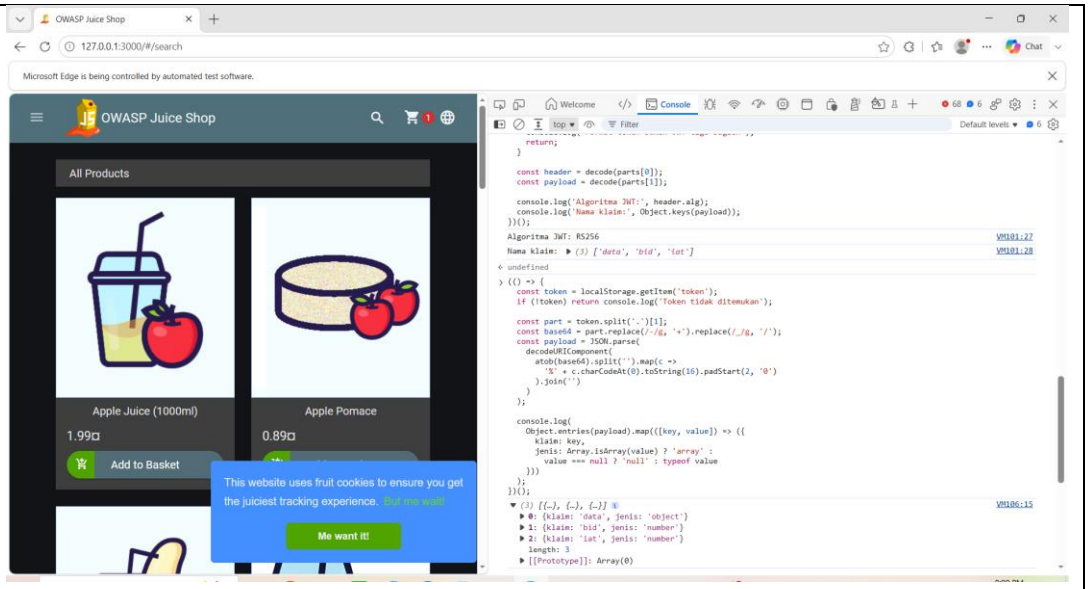
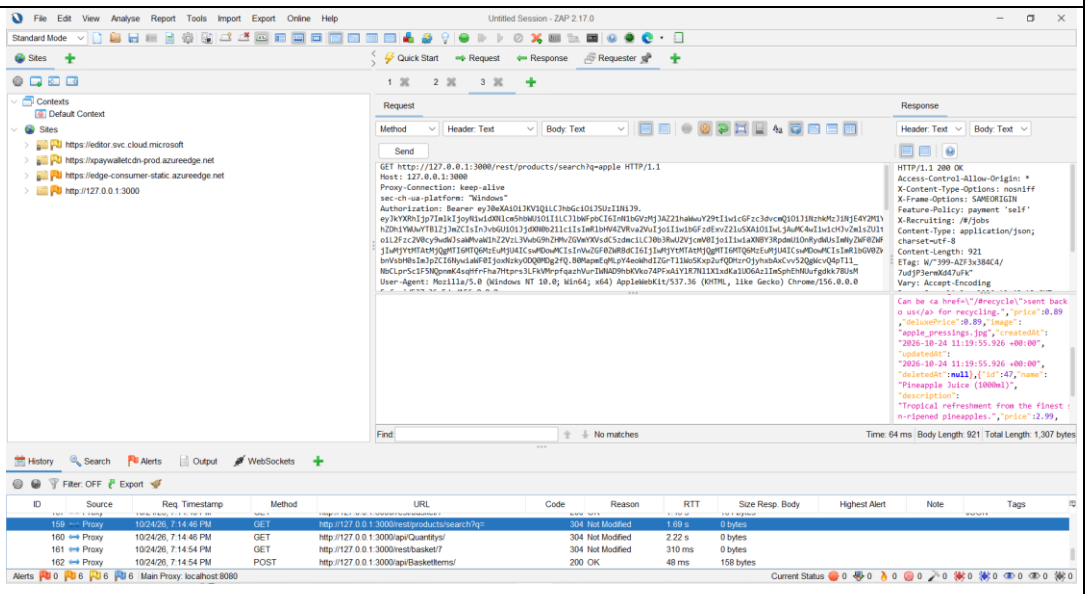
						bukti langsung untuk CWE-778.
R-18	A-05	A10 — Mishandling of Exceptional Conditions	Penanganan URL tidak dikenal	— (CWE-209 tidak terbukti)	Tidak ditemukan	Ketika URL /halaman-tidak-ada-123 dibuka, aplikasi menampilkan halaman utama Juice Shop dan tidak menampilkan pesan error teknis atau informasi internal server. Pada pengamatan ini tidak ditemukan indikasi pengungkapan informasi melalui pesan kesalahan; CWE-209 tidak terbukti.

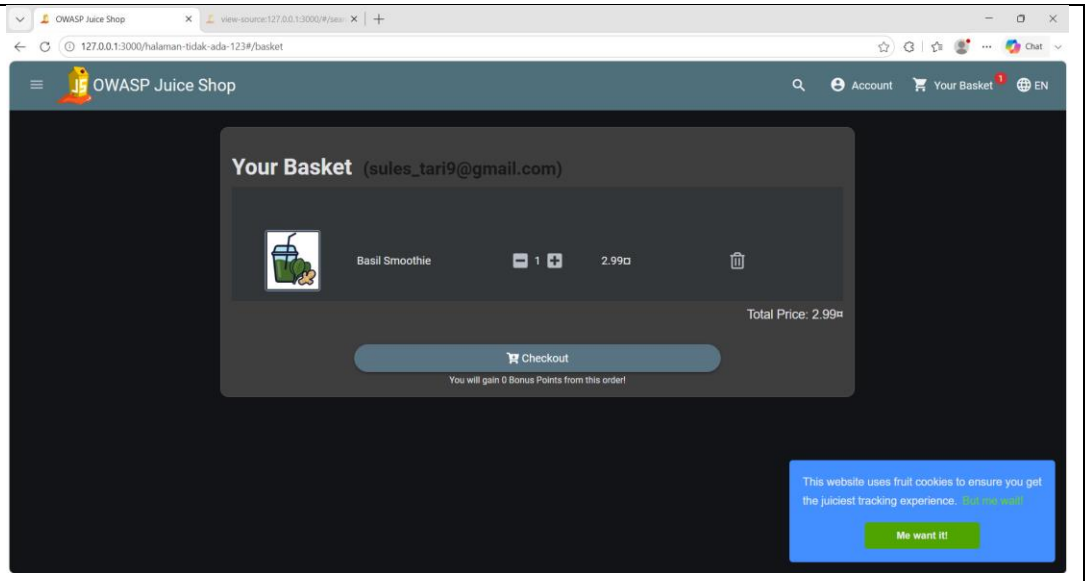
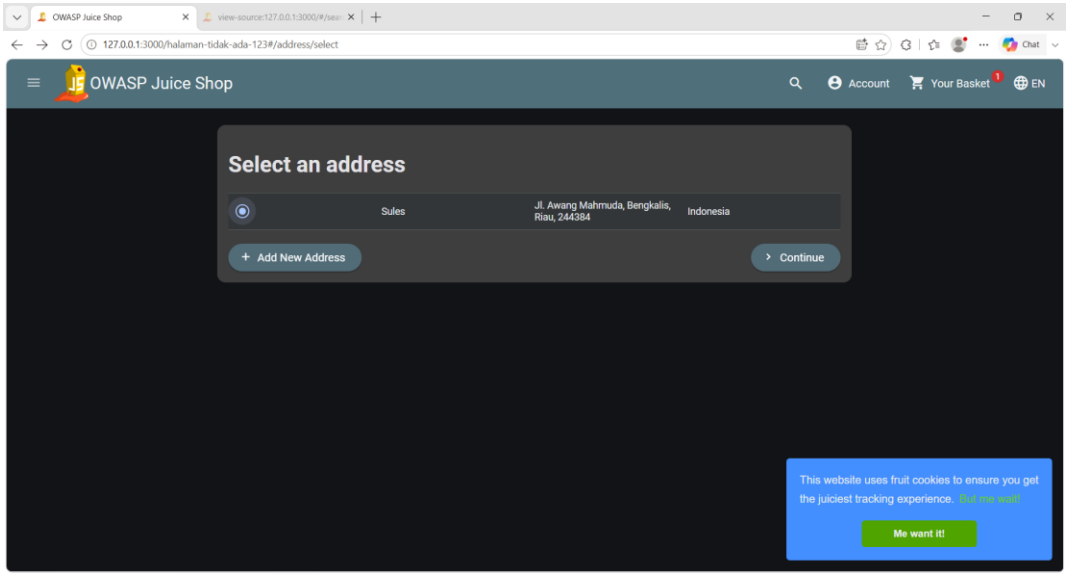
Screenshot sebagai bukti pengamatan:

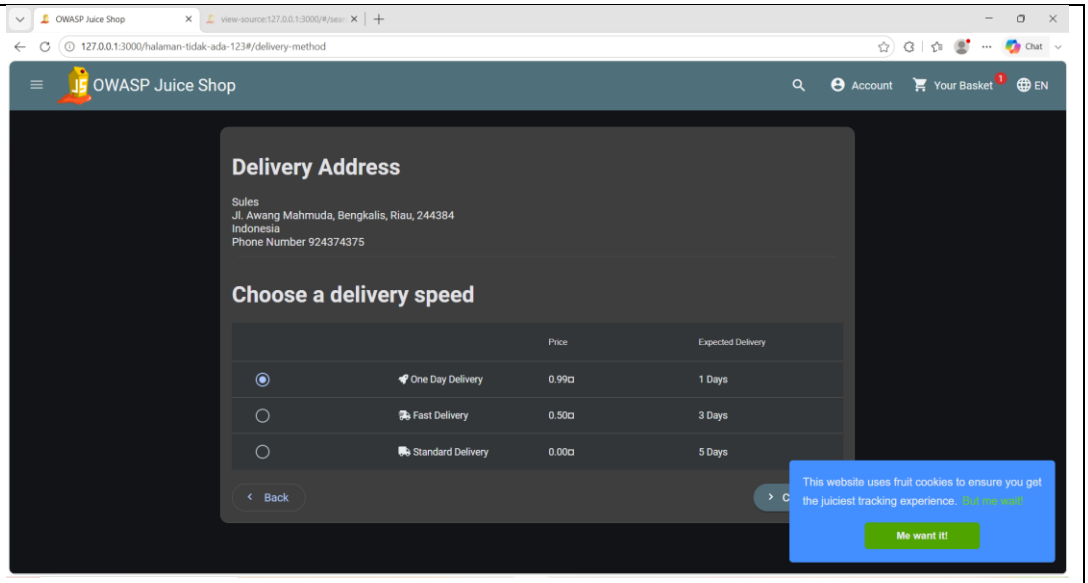
Kategori	Bukti Pengamatan

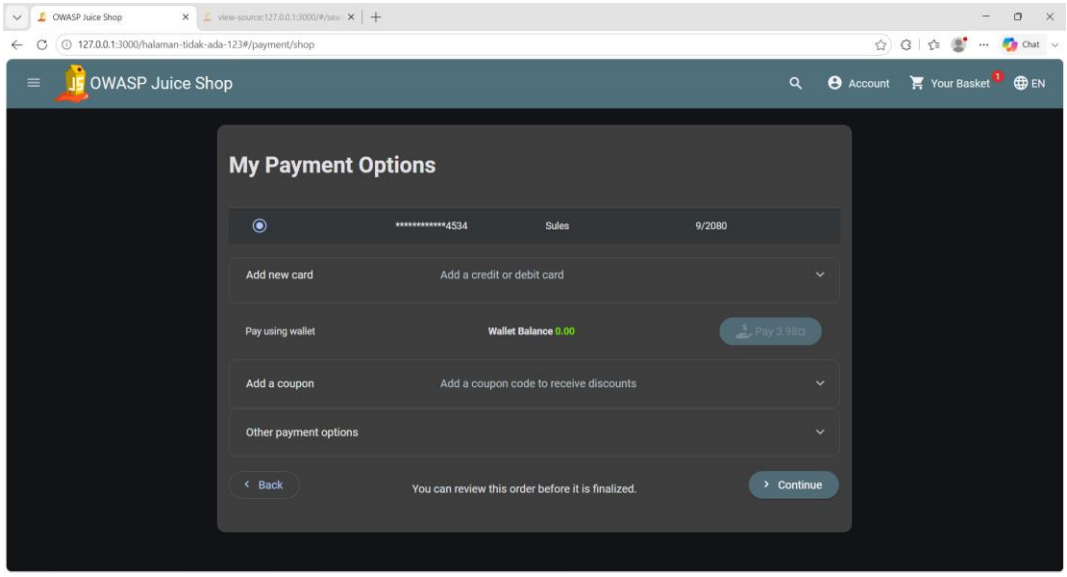
A01 — Broken Access Control	
A02 — Security Misconfiguration	

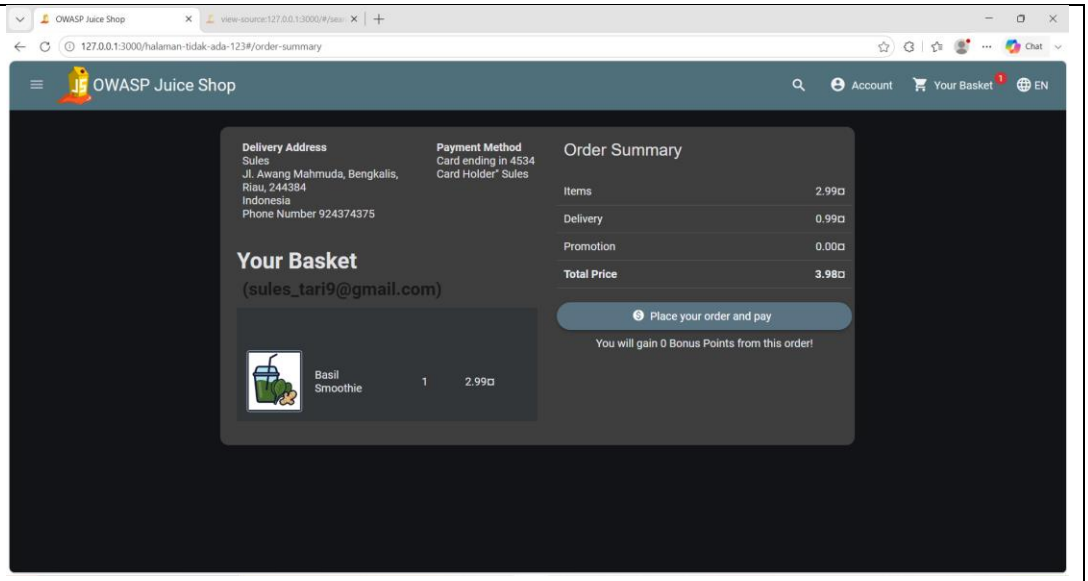
A03 — Software Supply Chain Failures	
A04 — Cryptographic Failures	

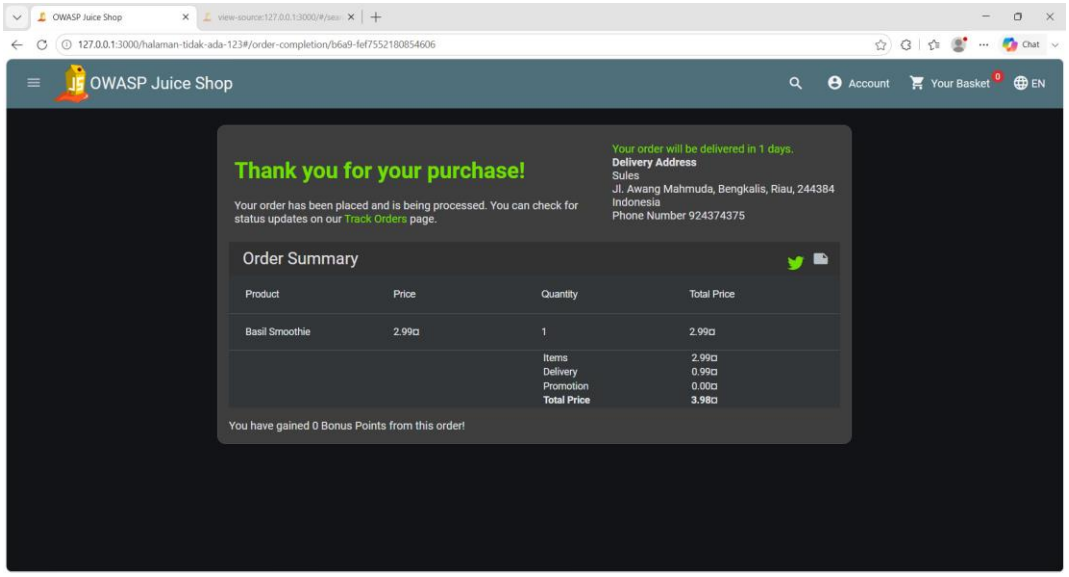
	
A05 — Injection	

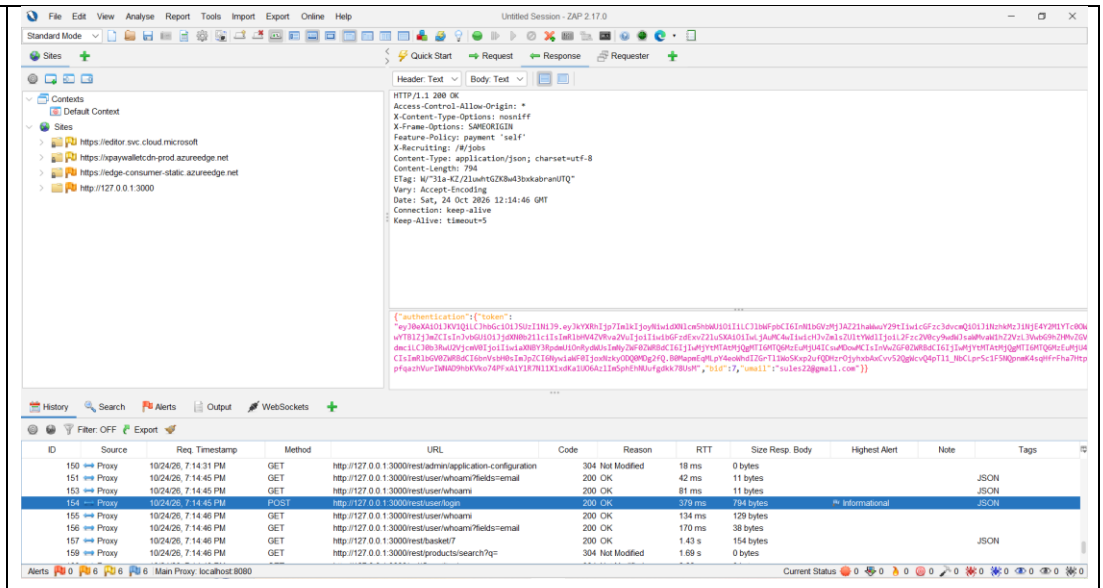
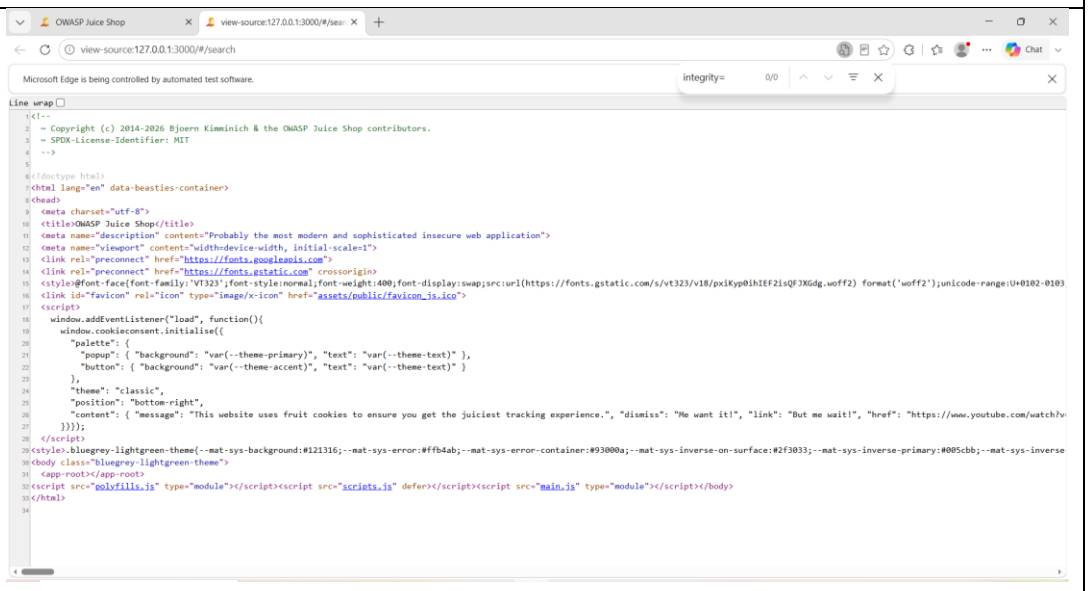
A06 — Insecure Design	 

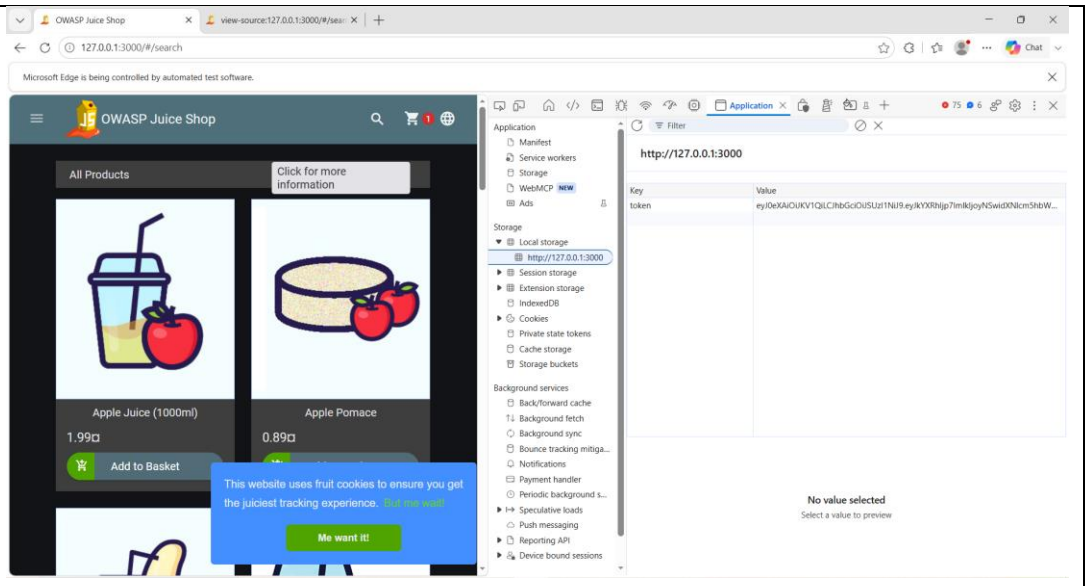
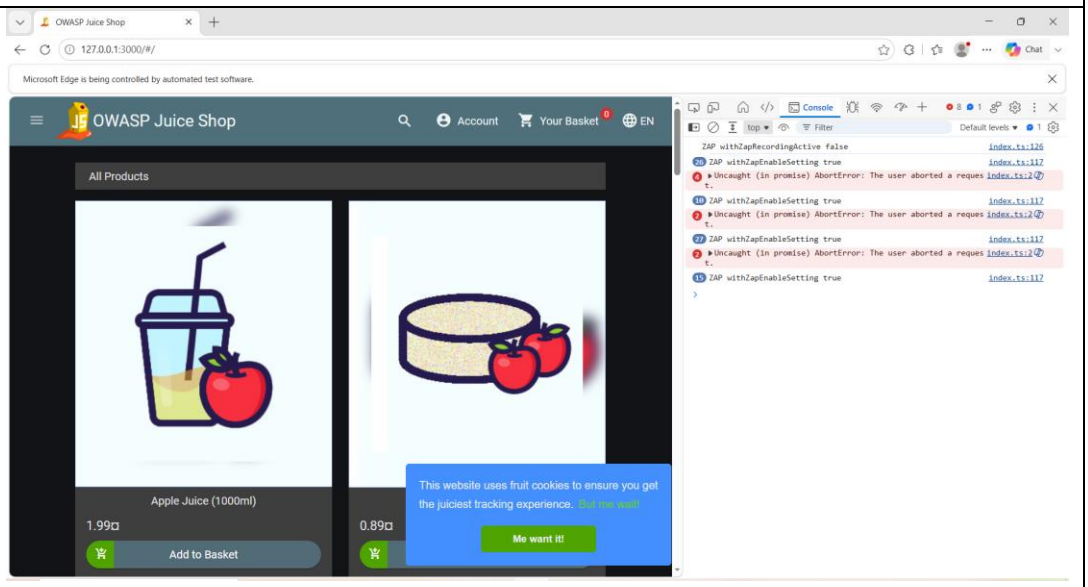

OWASP Juice Shop
127.0.0.1:3000/halaman-tidak-ada-123#/delivery-method
OWASP Juice Shop
Account
Your Basket
EN
Delivery Address
Sules
Jl. Awang Mahmuda, Bengkalis, Riau, 244384
Indonesia
Phone Number 924374375
Choose a delivery speed
Price
Expected Delivery
One Day Delivery
0.99¤
1 Days
Fast Delivery
0.50¤
3 Days
Standard Delivery
0.00¤
5 Days
Back
This website uses fruit cookies to ensure you get the juiciest tracking experience.
Me want it!

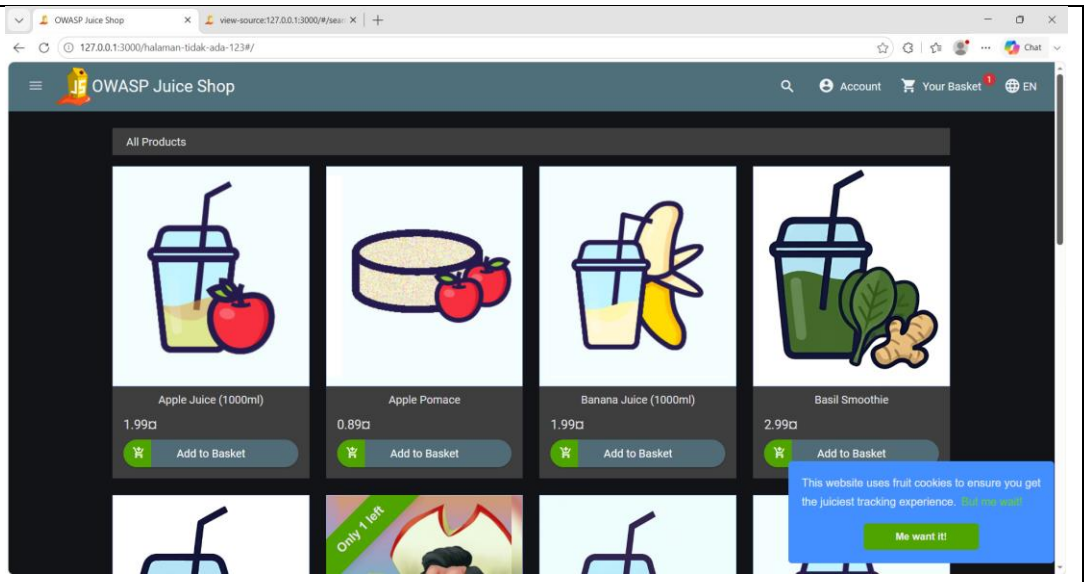

OWASP Juice Shop
127.0.0.1:3000/halaman-tidak-ada-123#/payment/shop
OWASP Juice Shop
Account
Your Basket
EN
My Payment Options
**********4534
Sules
9/2080
Add new card
Add a credit or debit card
Pay using wallet
Wallet Balance 0.00
Add a coupon
Add a coupon code to receive discounts
Other payment options
Back
You can review this order before it is finalized.
Continue


OWASP Juice Shop
127.0.0.1:3000/halaman-tidak-ada-123#/order-summary
OWASP Juice Shop
Account
Your Basket
EN
Delivery Address
Sules
Jl. Awang Mahmuda, Bengkalis, Riau, 244384
Indonesia
Phone Number 924374375
Payment Method
Card ending in 4534
Card Holder" Sules
Order Summary
Items 2.99¤
Delivery 0.99¤
Promotion 0.00¤
Total Price 3.98¤
Your Basket
(sules_tari9@gmail.com)
Basil Smoothie 1 2.99¤
Place your order and pay
You will gain 0 Bonus Points from this order!


OWASP Juice Shop
127.0.0.1:3000/halaman-tidak-ada-123#/order-completion/b6a9-fef7552180854606
OWASP Juice Shop
Account
Your Basket
EN
Thank you for your purchase!
Your order has been placed and is being processed. You can check for status updates on our Track Orders page.
Your order will be delivered in 1 days.
Delivery Address
Sules
Jl. Awang Mahmuda, Bengkalis, Riau, 244384
Indonesia
Phone Number 924374375
Order Summary
Product Price Quantity Total Price
Basil Smoothie 2.99¤ 1 2.99¤
Items 2.99¤
Delivery 0.99¤
Promotion 0.00¤
Total Price 3.98¤
You have gained 0 Bonus Points from this order!

A07 — Authentication Failures	
A08 — Software or Data Integrity Failures	

	
A09 — Security Logging and Alerting Failures	

A10 — Mishandling of Exceptional Conditions	

PEMETAAN LABEL KE TOP 10:2025

Catatan: Tabel ini memetakan label kategori Juice Shop secara konseptual ke OWASP Top 10:2025 berdasarkan akar penyebab. Pemetaan dan CWE representatif tidak berarti kerentanan tersebut terbukti ditemukan pada pengamatan dalam Vulnerability Checklist.

No.	Label kategori Juice Shop	Kategori OWASP Top 10:2025	CWE representatif	Alasan pemetaan
1	Broken Access Control	A01 — Broken Access Control	CWE-639	Berkaitan dengan akses objek atau data tanpa pemeriksaan otorisasi yang memadai.
2	Security Misconfiguration	A02 — Security Misconfiguration	CWE-16	Berkaitan dengan konfigurasi aplikasi atau server yang tidak aman.
3	Vulnerable Components	A03 — Software Supply Chain Failures	CWE-1104	Berkaitan dengan penggunaan komponen perangkat lunak pihak ketiga yang tidak dipelihara.

				A03:2025 mencakup risiko rantai pasok yang lebih luas.
4	Cryptographic Issues	A04 — Cryptographic Failures	CWE-327	Berkaitan dengan penggunaan algoritma atau mekanisme kriptografi yang lemah atau tidak aman.
5	Injection	A05 — Injection	CWE-89	Berkaitan dengan input tidak tepercaya yang diproses sebagai bagian dari kueri SQL.
6	Business Logic Flaw	A06 — Insecure Design	CWE-501 (usulan)	Berkaitan dengan pelanggaran batas kepercayaan atau kelemahan desain alur bisnis. Pemetaan ini memerlukan bukti akar penyebab yang sesuai.
7	Broken Authentication	A07 — Authentication Failures	CWE-307	Berkaitan dengan pembatasan percobaan autentikasi yang tidak memadai.
8	Insecure Deserialization	A08 — Software or Data Integrity Failures	CWE-502	Berkaitan dengan pemrosesan data hasil deserialisasi yang tidak aman.
9	Observability Failures	A09 — Security Logging and Alerting Failures	CWE-778	Berkaitan dengan pencatatan kejadian keamanan yang tidak memadai.

10	Error Handling	A10 — Mishandling of Exceptional Conditions	CWE-209	Berkaitan dengan pesan kesalahan yang mengungkapkan informasi sensitif.

REFLEKSI

A03 — *Software Supply Chain Failures* menekankan risiko keamanan pada komponen, pustaka, dan dependensi pihak ketiga yang digunakan aplikasi. A10 — *Mishandling of Exceptional Conditions* menekankan pentingnya menangani kondisi tidak normal atau kesalahan secara aman agar tidak menimbulkan risiko keamanan. Pada aplikasi Laravel yang saya kembangkan, saya perlu memperbarui dependensi secara berkala dan memeriksa kerentanan pada paket yang digunakan. Selain itu, saya perlu memastikan aplikasi menangani kesalahan dengan baik tanpa membocorkan informasi teknis atau data sensitif kepada pengguna.

PEMERIKSAAN CAKUPAN

Jumlah baris dihitung dari Vulnerability Checklist R-09 sampai R-18. Kolom “Berbukti?” menunjukkan apakah tersedia bukti pengamatan untuk kategori tersebut, bukan apakah kerentanannya telah terbukti.

Kategori	**Jumlah baris pada checklist**	**Berbukti? (ya/tidak)**
A01 — Broken Access Control	1	Ya
A02 — Security Misconfiguration	1	Ya
A03 — Software Supply Chain Failures	1	Ya
A04 — Cryptographic Failures	1	Ya
A05 — Injection	1	Ya
A06 — Insecure Design	1	Ya
A07 — Authentication Failures	1	Ya
A08 — Software or Data Integrity Failures	1	Ya
A09 — Security Logging and Alerting Failures	1	Ya

A10 — Mishandling of Exceptional Conditions	1	Ya